

User Access and Permissions

A practical introduction to AWS security, IAM and access management

Table of Contents

RECAP	IAM & Least Privilege Review mission statement and the principle of least privilege
01	Security, Compliance & IAM Explore AWS security services, compliance tools and identity management
02	Practice Lab Configure IAM users, groups and permissions using least privilege

00 IAM & Least Privilege

Background

Our Support Engineering team is growing.

- All engineers need the same permissions.
- They need view access to EC2 and RDS.
- They need access through the AWS Management Console and developer tools such as the AWS CLI.
- New engineers should automatically receive the correct permissions.
- We may need custom permissions later.

Problems

The Support Engineering team is growing, and every team member needs the same AWS permissions.

- View Amazon EC2 and Amazon RDS resources.
- Access AWS through the Management Console and developer tools such as the AWS CLI.
- Automatically receive the correct permissions when added to the Support Engineering team.
- Allow custom permissions to be created later if predefined permissions are not suitable.

Solution

Use AWS Identity and Access Management (IAM). Create an IAM group for Support Engineering and assign the required permissions to the group. Then add each support engineer to that group.

AWS provides managed policies, so we do not need to manually define every permission. Existing read-only policies can be attached for EC2 and RDS.

If the predefined policies do not meet our requirements, we can create a custom IAM policy with exactly the permissions we need.

When creating users, configure the required access methods, such as the AWS Management Console and developer tools, and add them to the Support Engineering group.

Recap - Least Privilege

Least privilege means giving users only the permissions they need to perform their job, and nothing more.

For example, if Support Engineers only need to view EC2 and RDS resources, they should receive read-only access rather than permissions to create, modify, or delete resources.

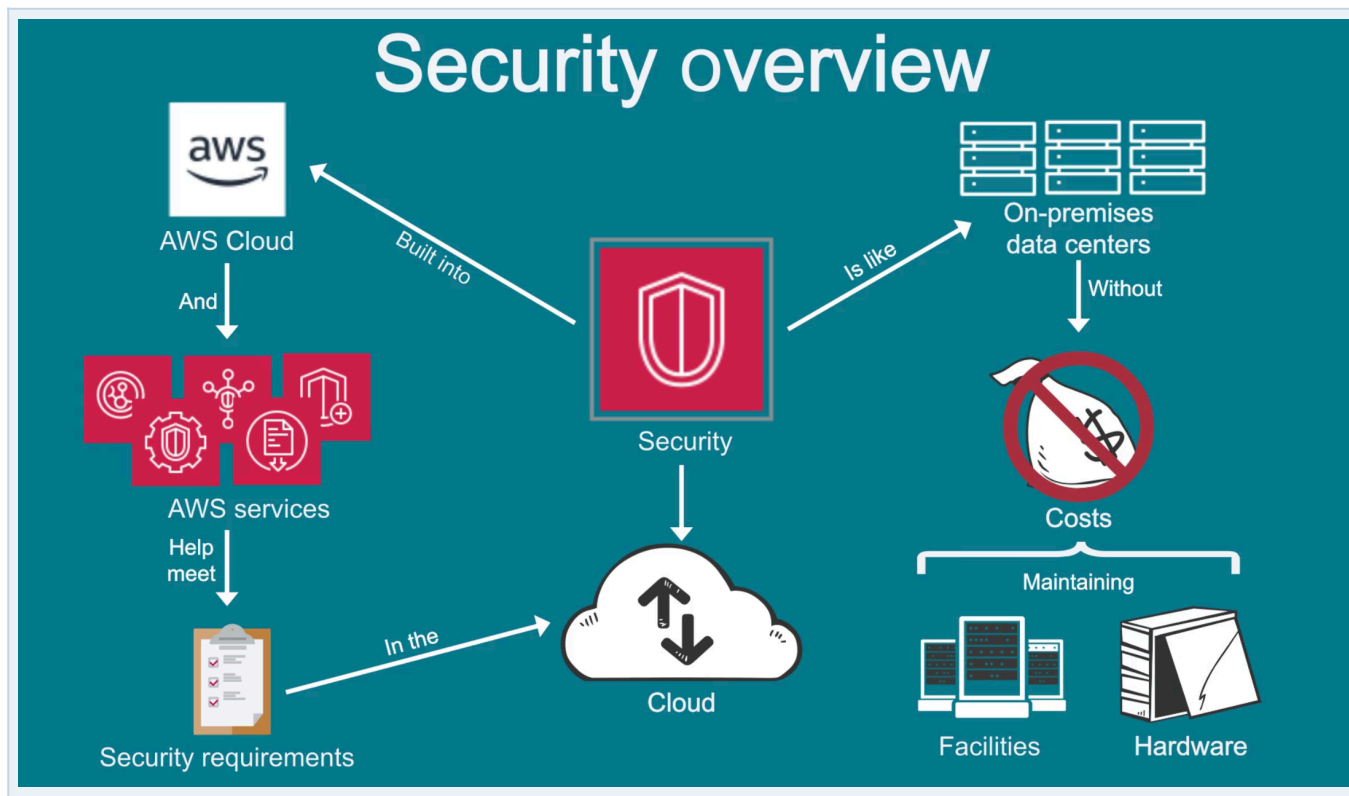
This improves security by limiting what a user can accidentally change and reducing the damage that could occur if an account is compromised.

01 Security, Compliance & IAM

Security & Compliance

Security in AWS is built into the cloud and its services. AWS provides security tools and infrastructure that help organisations meet their security requirements without having to build and maintain all of the underlying infrastructure themselves.

Compared with an on-premises data centre, AWS manages the physical facilities and hardware, reducing the cost and responsibility of maintaining that infrastructure. Security is therefore integrated into the AWS environment rather than something an organisation has to build entirely from scratch.



NOTE: AWS providing secure infrastructure does not mean AWS handles all security. Security responsibilities are shared between AWS and the customer.

Different countries and industries have different security and compliance requirements. AWS maintains global and regional compliance programs and provides controls that help customers meet these requirements.

AWS supports standards and regulations such as PCI DSS, HIPAA/HITECH, FedRAMP, GDPR, FIPS 140-2, and NIST 800-171.

This reduces the amount of compliance infrastructure customers need to build themselves while helping them meet requirements from regulators and their industries.

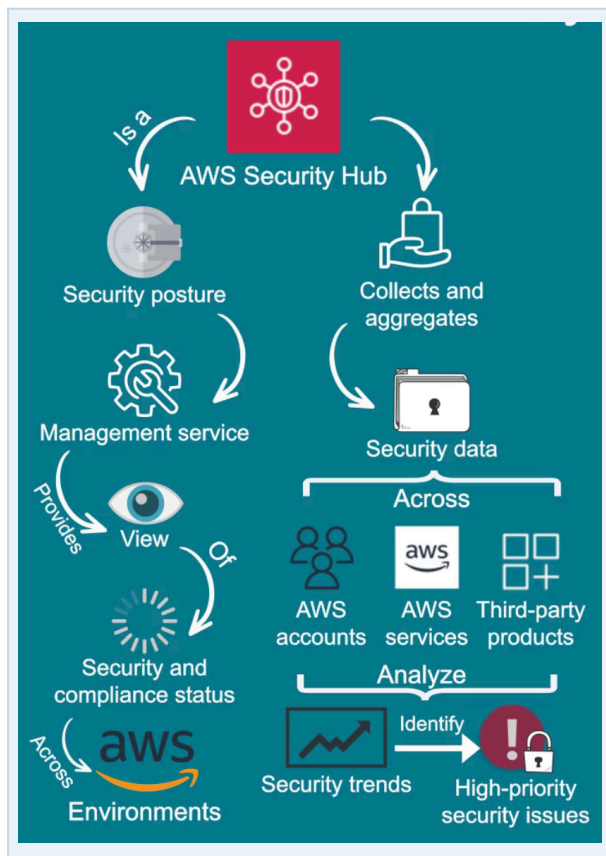
Compliance overview



NOTE: Using AWS does not automatically make an application compliant. AWS provides compliant infrastructure and controls, while customers are still responsible for configuring and using AWS services appropriately.

AWS Security Hub

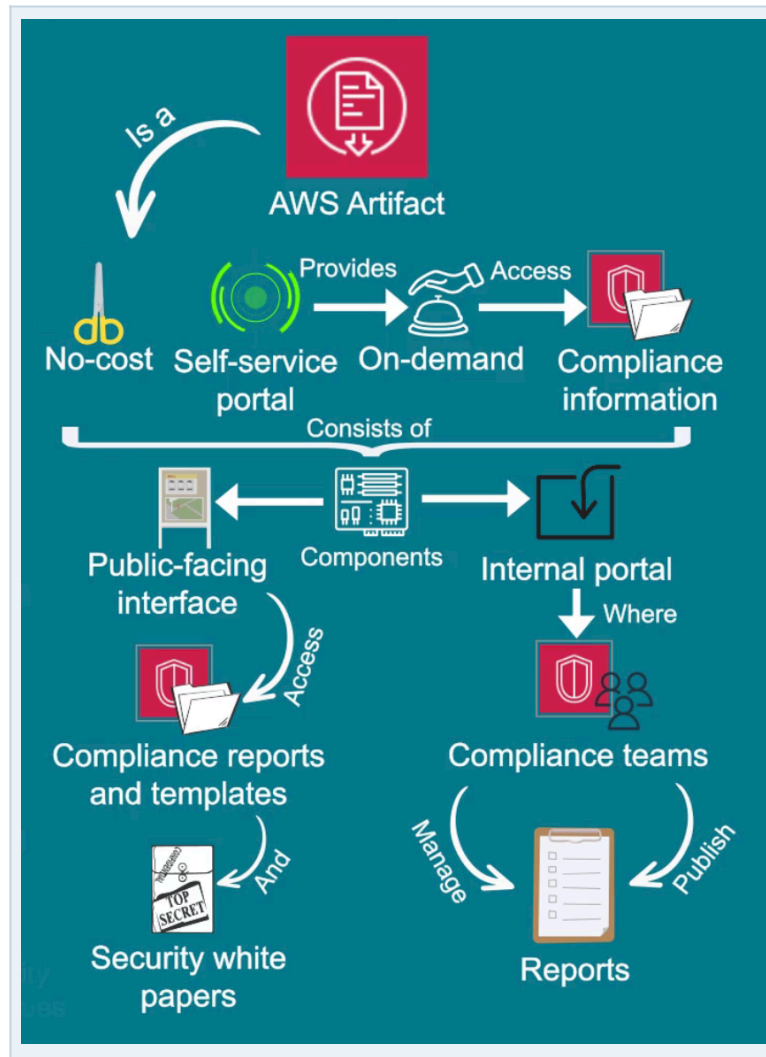
- Provides a central view of security and compliance.
- Collects security data from AWS accounts and services.
- Collects findings from third-party security products.
- Identifies security trends.
- Highlights high-priority security issues.
- Makes it easier to monitor security across multiple accounts and services.



NOTE: Think of Security Hub as a central security dashboard. It brings security findings together so you can see what needs attention.

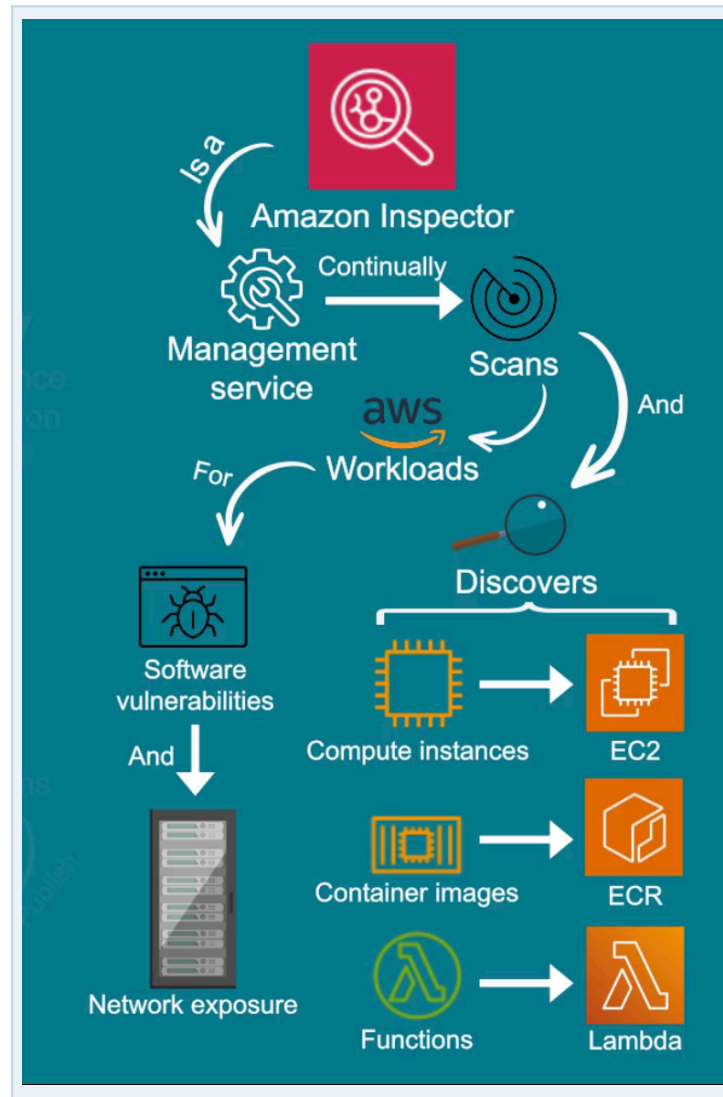
AWS Artifact

- No-cost, self-service portal.
- On-demand access to AWS compliance information.
- Access to compliance reports, certifications, and security documentation.
- Provides documents that can be used for audits.
- AWS compliance teams manage and publish the reports.



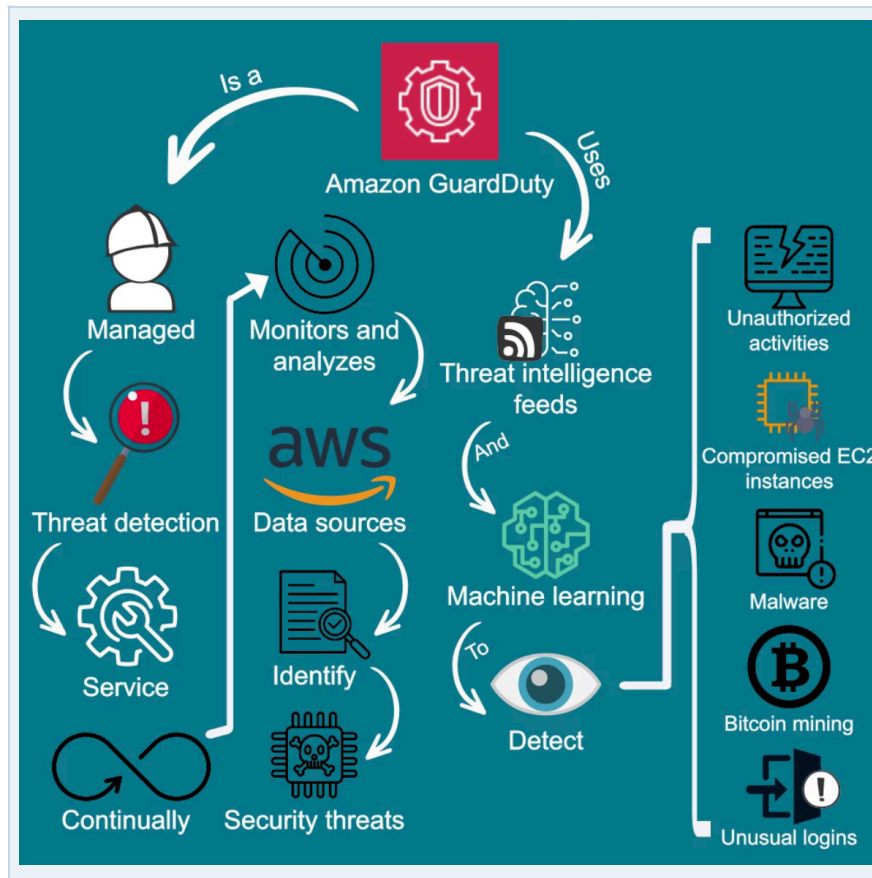
Amazon Inspector

- Continuously scans AWS workloads for vulnerabilities.
- Scans EC2 instances, Amazon ECR container images, and AWS Lambda functions.
- Detects software vulnerabilities and unintended network exposure.
- Helps identify security weaknesses that need to be fixed.



Amazon GuardDuty

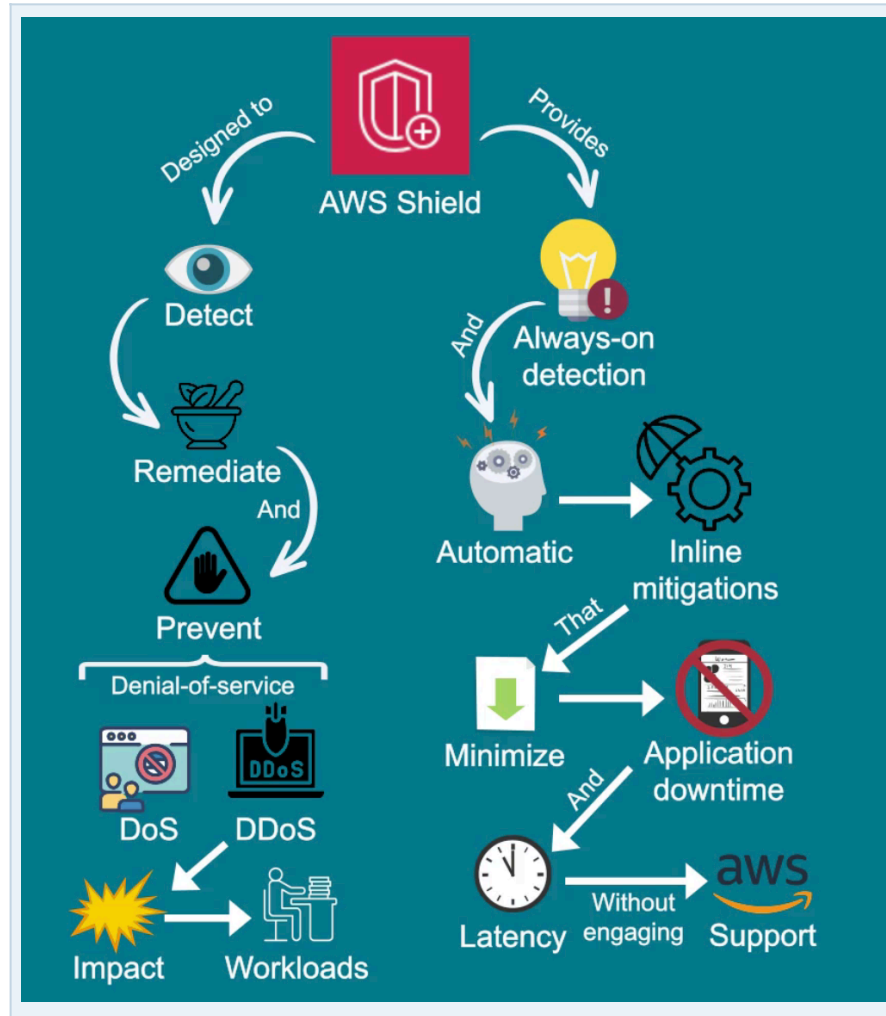
- Continuously monitors AWS for threats.
- Detects suspicious and malicious activity.
- Uses threat intelligence and machine learning.
- Can identify unauthorised activity, compromised EC2 instances, malware, unusual logins, and cryptocurrency mining.



NOTE: Inspector finds vulnerabilities, while GuardDuty detects threats that may already be happening.

AWS Shield

- Protects AWS applications from DoS and DDoS attacks.
- Provides always-on attack detection and automatic mitigation.
- Helps reduce application downtime and latency caused by attacks.
- Requires little to no manual intervention.



NOTE: GuardDuty detects suspicious activity across the AWS environment, while Shield specifically protects against DoS and DDoS attacks.

AWS IAM

Overview

AWS IAM manages who can access AWS and what they are allowed to do.

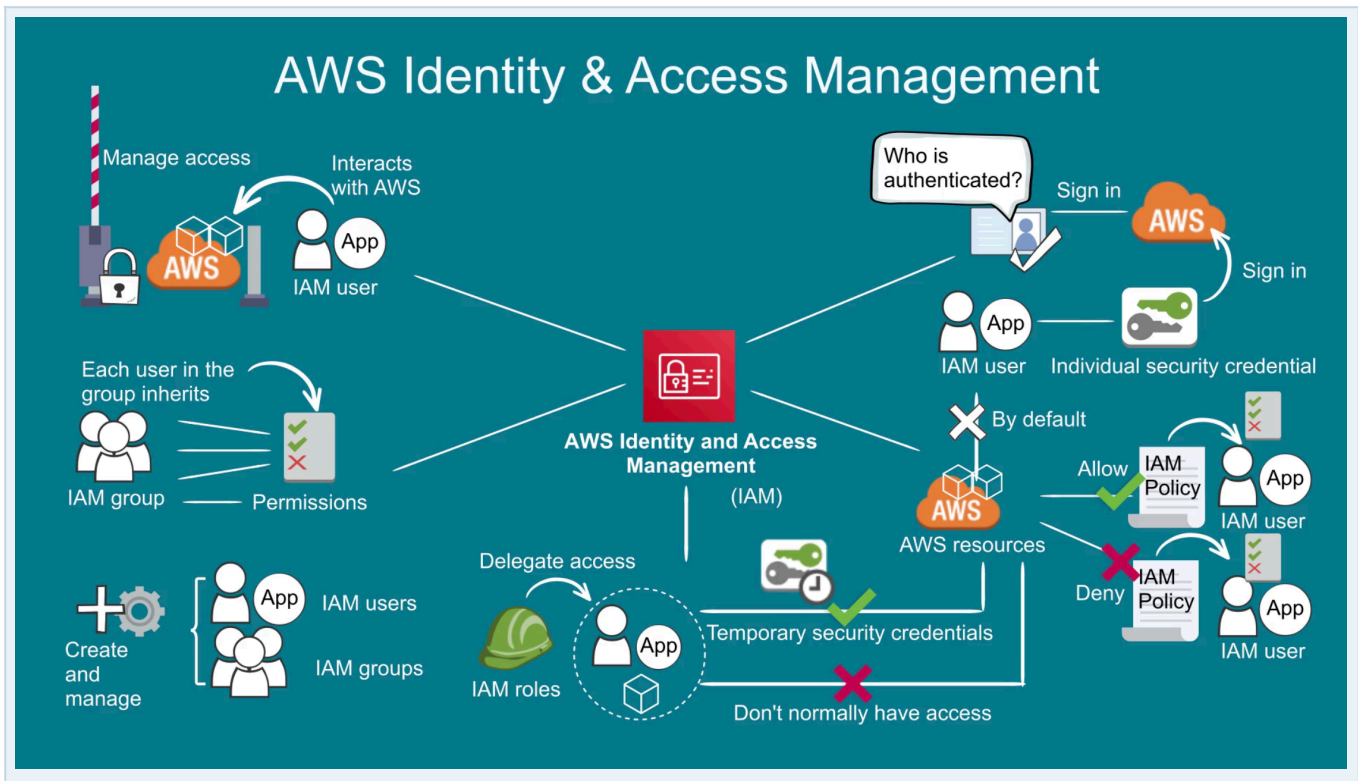
IAM lets you create and manage:

- Users
- Groups
- Roles
- Policies

Groups, Users & Roles

Users can have individual credentials, while groups make it easier to give multiple users the same permissions. By default, users do not have access to AWS resources until permissions are granted through IAM policies.

IAM roles provide temporary access to users, applications, and AWS services without having to give them permanent credentials.



NOTE: IAM separates authentication (who are you?) from authorization (what are you allowed to do?).

Fine-Grained Access Control

IAM policies can control access to AWS resources using specific conditions, not just simple allow or deny permissions.

Access can be restricted based on things such as:

- Time of day.
- Originating IP address.
- Whether a secure connection is being used.
- Whether the user authenticated with MFA.

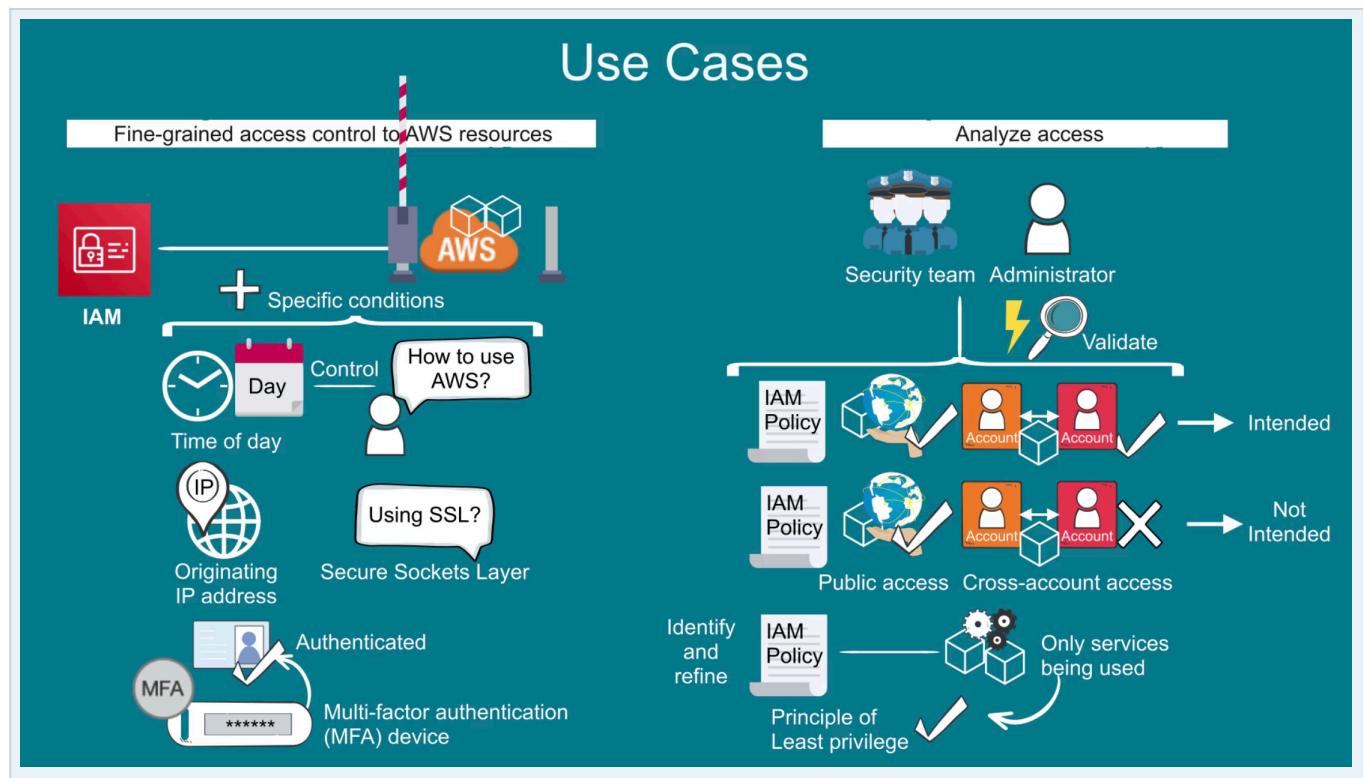
This allows permissions to be tailored closely to how and when a resource should be accessed.

Analyse Access

IAM can help administrators and security teams review who has access to AWS resources and identify permissions that may be broader than intended.

This includes identifying public access and cross-account access and refining IAM policies when unnecessary permissions are found.

Access analysis also supports least privilege, where users and services receive only the permissions they actually need.



NOTE: Fine-grained access controls how access is allowed. Access analysis helps verify that the resulting access is actually what you intended.

Multi-Factor Authentication (MFA)

IAM supports multi-factor authentication to provide additional protection for AWS accounts, especially highly privileged users.

Instead of signing in with only a username and password, the user must also provide a valid code from an MFA device, such as a mobile authenticator or hardware token.

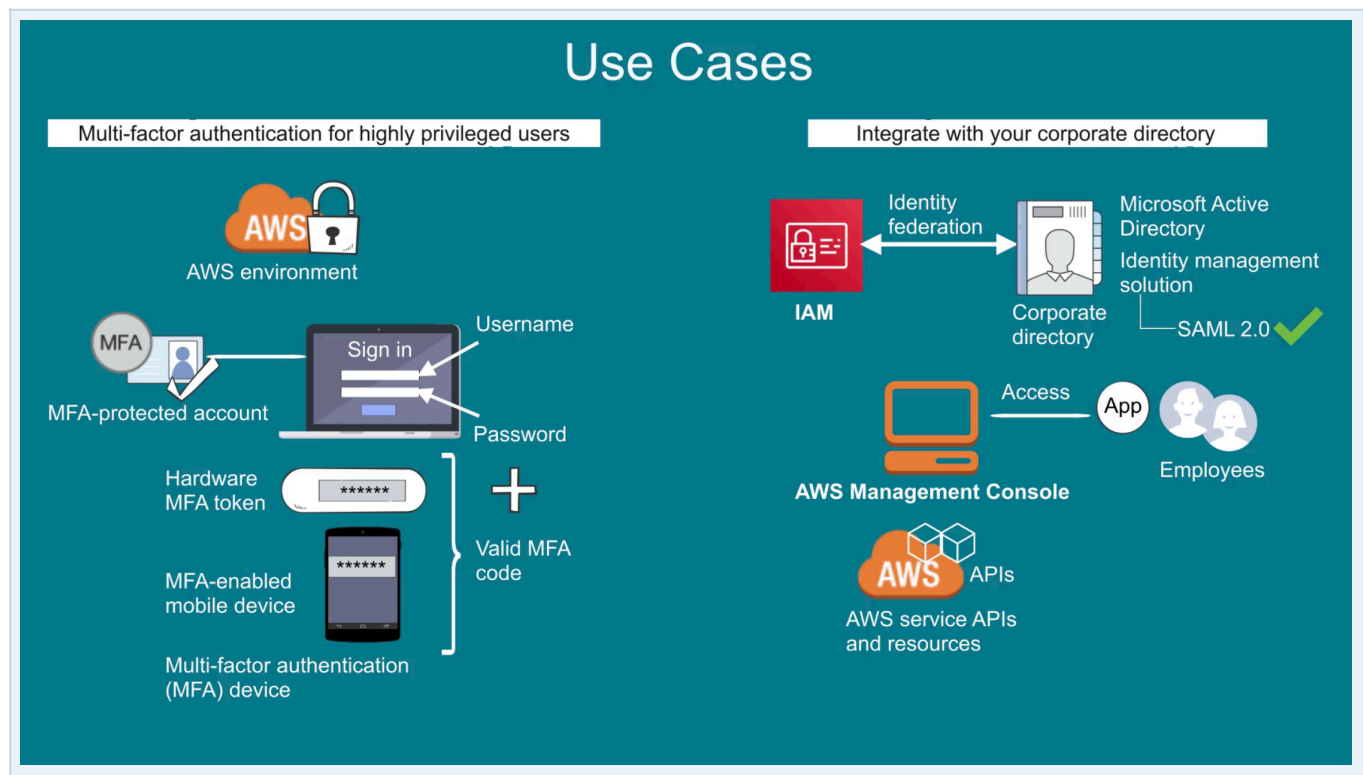
This means a stolen password alone is not enough to access the account.

Integrate with a Corporate Directory

AWS can integrate with an organisation's existing corporate identity system, such as Microsoft Active Directory.

Through identity federation, employees can use their existing company identities to access the AWS Management Console and AWS resources instead of maintaining separate IAM user credentials.

The diagram shows SAML 2.0 as the federation standard connecting the corporate directory with AWS.



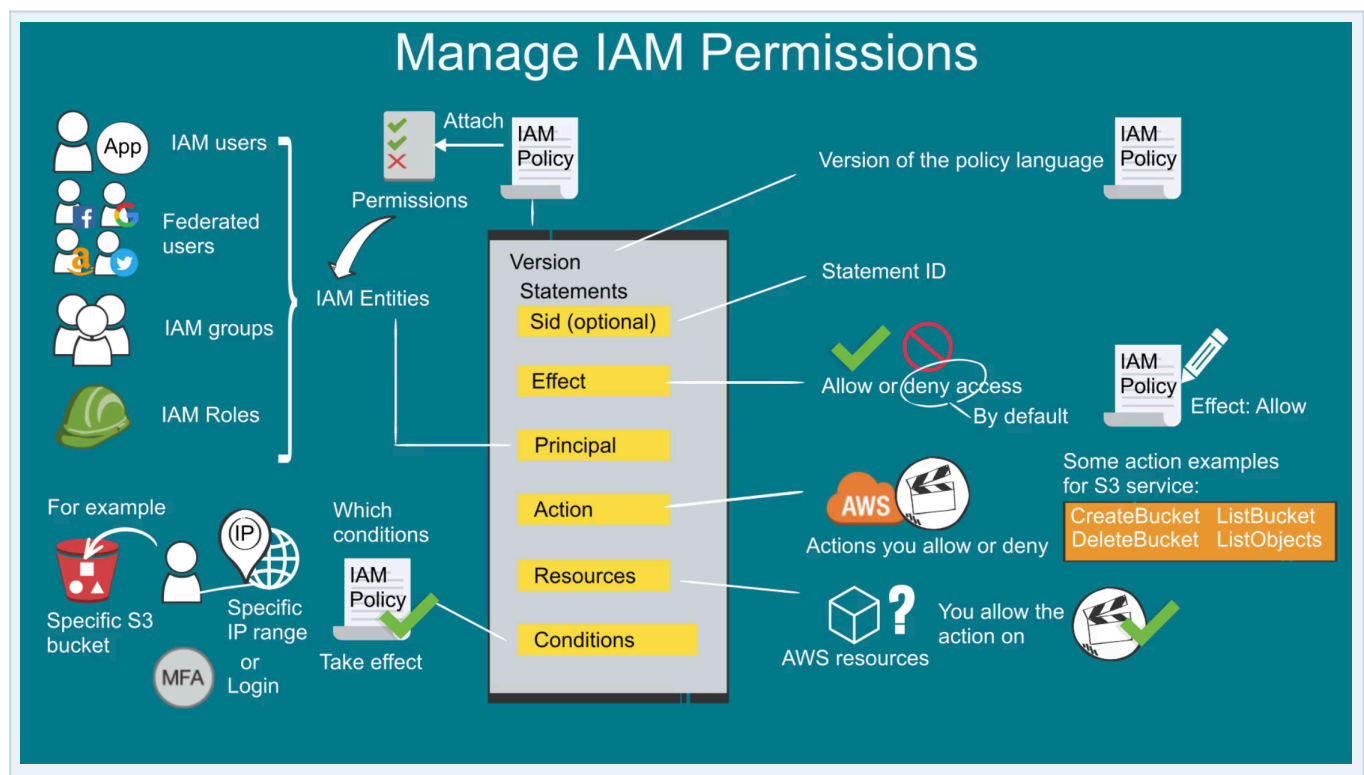
NOTE: MFA adds another factor to verify a user's identity. Federation lets users reuse an existing organisational identity to access AWS.

Manage IAM Permissions

An IAM policy is a set of rules that defines what someone is allowed or denied to do with AWS resources.

For example, a policy could allow actions such as `EC2:StartInstances`, `EC2:TerminateInstances`, or `S3:GetObject`.

Policy element	Meaning	Example
Effect	Allow or deny?	Allow
Action	What can they do?	<code>ec2:StartInstances</code>
Resource	What can they do it to?	EC2 instance
Condition	When is it allowed?	Only from company IP
Sid	Optional name for the rule	<code>AllowEC2Start</code>



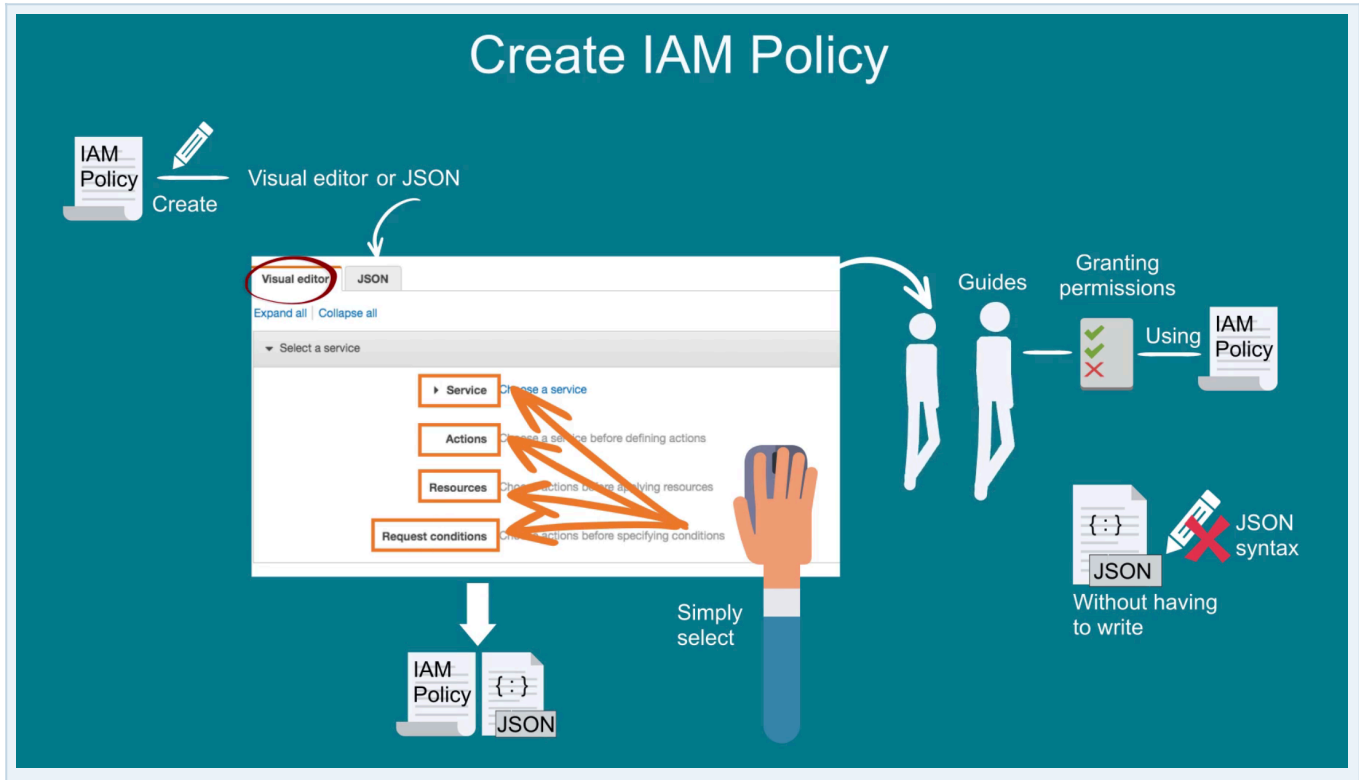
NOTE: Access is denied by default. An IAM policy must explicitly allow an action before it can be performed.

Creating an IAM Policy

IAM policies can be created using either the visual editor or JSON.

The visual editor lets you select the service, actions, resources, and conditions you want without writing the JSON policy manually. AWS then creates the underlying policy from those selections.

This makes it easier to create custom permissions without needing to know IAM policy syntax.



NOTE: The visual editor and JSON are two ways of creating the same type of IAM policy.

The IAM visual editor lets you build a policy by selecting the AWS service, actions, resources, and conditions.

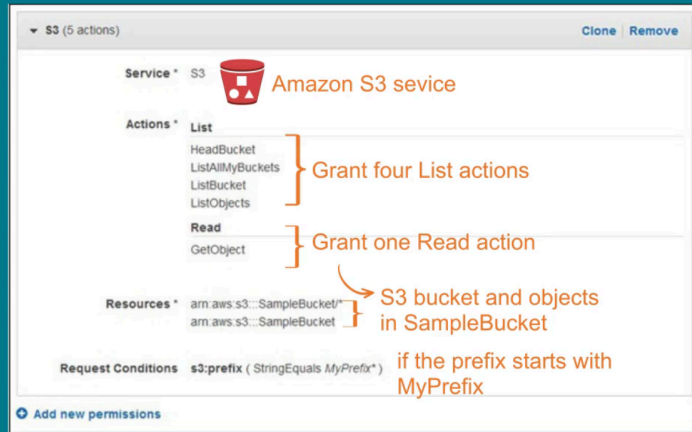
In this example, the policy is for Amazon S3. It allows several List actions and a Read action (GetObject) on a specific S3 bucket and its objects, with an additional condition.

AWS groups actions into access levels such as:

- List - view or list resources.
- Read - read resource contents.
- Tagging - manage tags.
- Write - create, change, or delete resources.
- Permissions management - change who has access.

Visual Editor Example

Policy example created with visual editor



NOTE: Selecting an access level does not mean every action is automatically allowed. The policy contains the specific actions you select within those categories.

IAM Access Analyzer

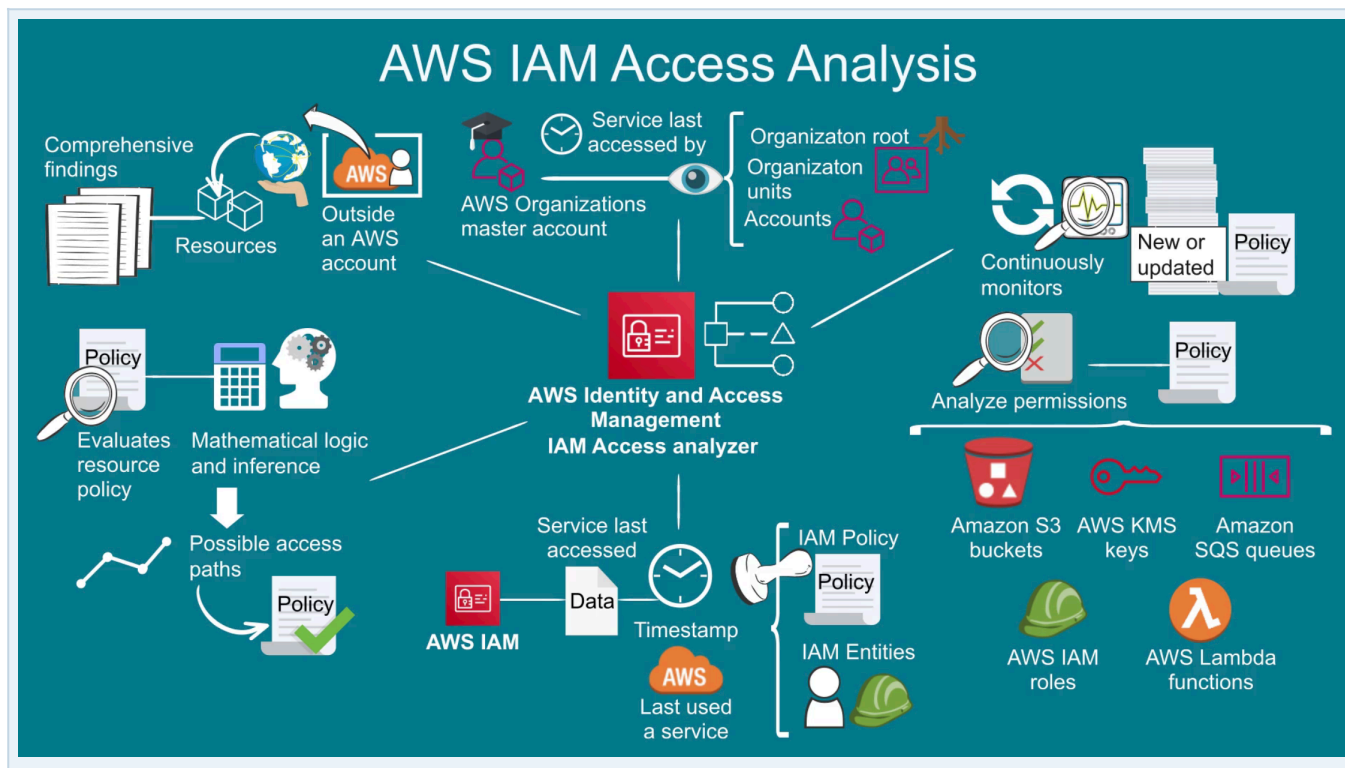
IAM Access Analyzer is an automated tool that analyses AWS policies to understand who can access what.

Imagine you have several AWS resources and policies, such as an S3 bucket, IAM role, SQS queue, and KMS key. Those policies can become complicated, so it becomes difficult to answer: “Who can actually access all this stuff?”

Access Analyzer examines those permissions and reports what access they create. For example, it can detect if an S3 bucket is configured so another AWS account can access it.

It helps:

- Map out access between users, accounts, and resources.
- Detect public or cross-account access.
- Find unused or unnecessary permissions.
- Flag access that may be unintended.



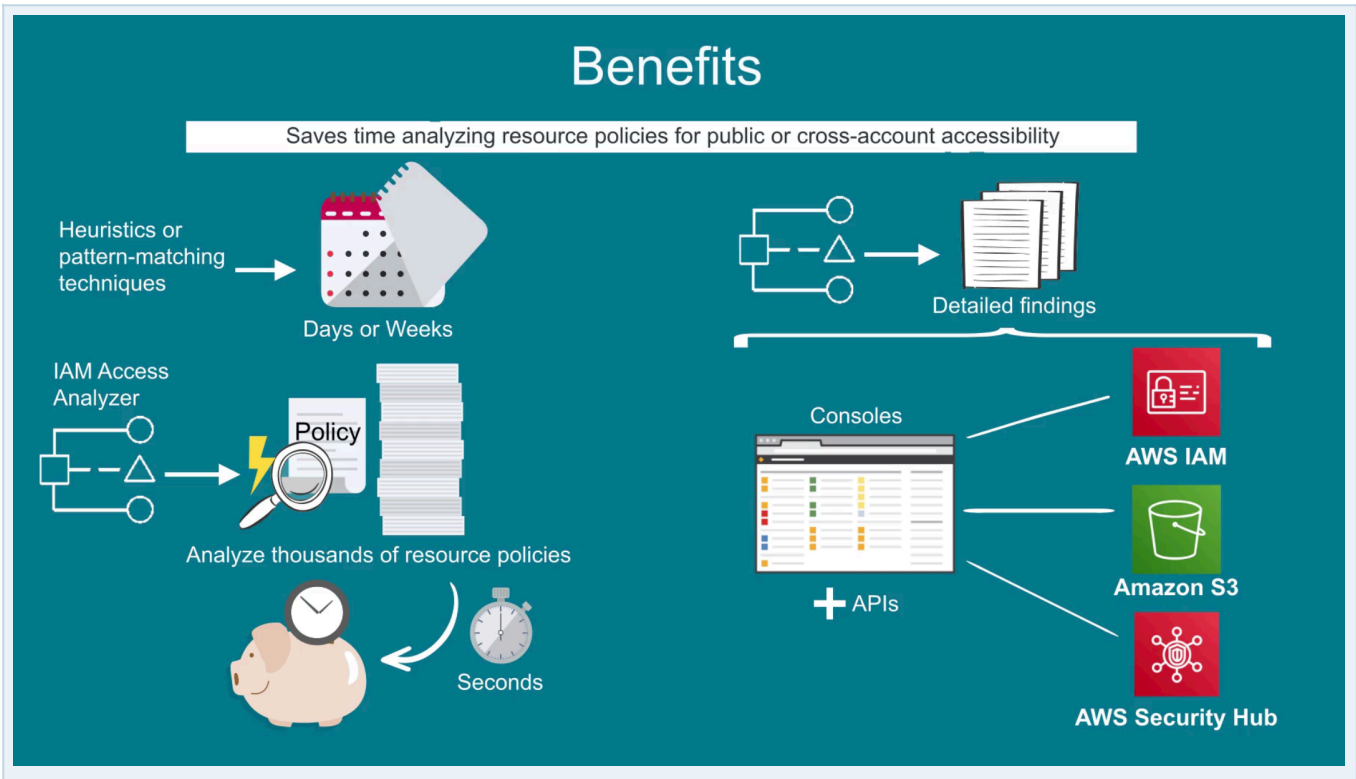
NOTE: Access Analyzer helps answer: “Who can access this, and do they actually need that access?” This helps maintain least privilege.

Benefits of IAM Access Analyzer

IAM Access Analyzer can analyse thousands of resource policies quickly to identify public or cross-account access.

It saves time compared with manually reviewing policies and produces detailed findings that can be viewed through AWS consoles or APIs. Findings can also integrate with services such as AWS Security Hub.

Benefits



NOTE: Access Analyzer automates permission analysis that could otherwise take significant time to review manually.

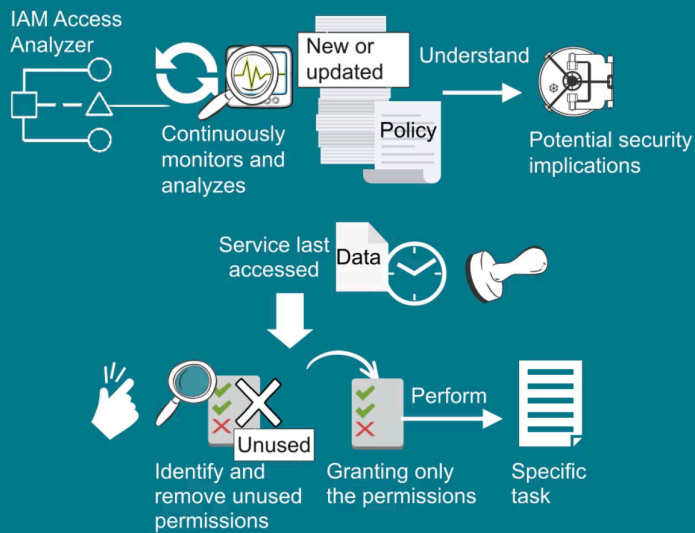
IAM Access Analyzer continuously monitors permissions and policies to help you understand their security impact.

It can help with:

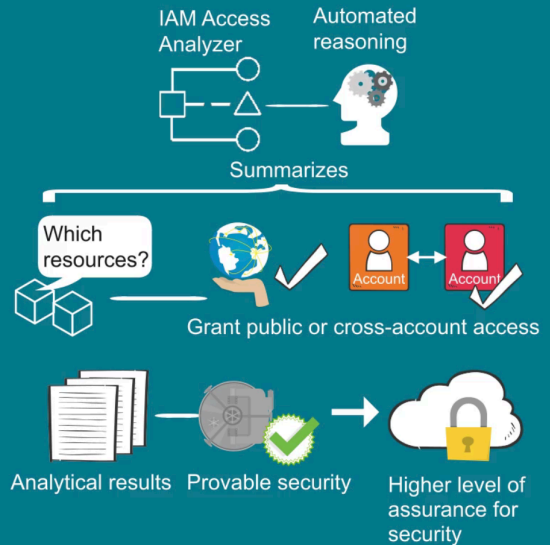
- Identifying unused permissions that can be removed.
- Refining permissions so users have only what they need.
- Detecting resources that allow public or cross-account access.
- Analysing policies using automated reasoning rather than manual review.

Benefits

Continuously monitors and helps you refine permissions



Provides the highest levels of security assurance



NOTE: Access Analyzer supports least privilege by showing where permissions may be broader than necessary.

How It Works

IAM Access Analyzer continuously scans resource policies and permissions and creates findings when it detects access that may need attention.

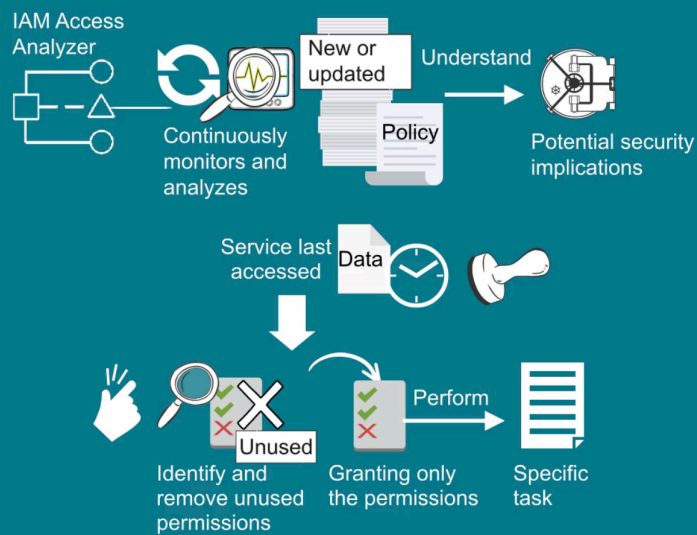
The process is:

1. Create an analyzer for an AWS account or organisation.
2. Review findings showing who can access your resources.
3. Take action: if access is not intended, modify the policy to restrict it; if access is intended, archive the finding.

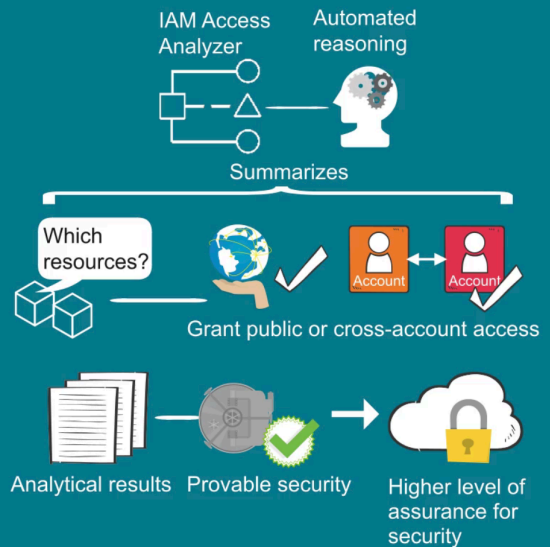
It also uses access data to help identify unused permissions, allowing you to refine policies and better follow least privilege.

Benefits

Continuously monitors and helps you refine permissions



Provides the highest levels of security assurance



NOTE: Access Analyzer finds and reports access; it does not automatically remove it. You review the finding and decide whether to change the policy.

IAM User Group Creation - Overview

What Are We Actually Building?

Imagine your company has several support engineers. They need to investigate problems with EC2 servers and RDS databases, but they should not be able to modify or delete them.

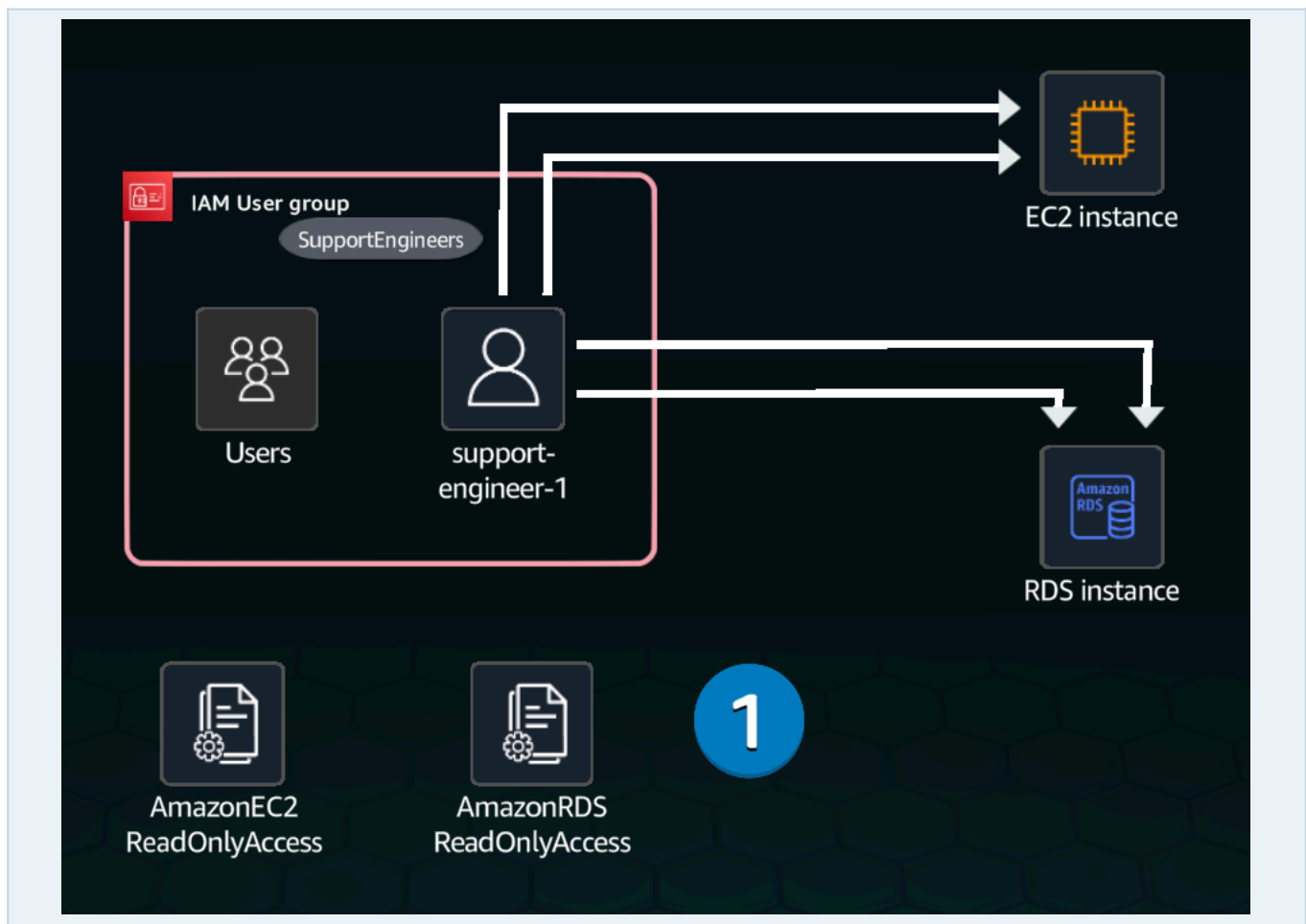
Instead of configuring permissions separately for every engineer, we create an IAM group named SupportEngineers and add the users to it.

- support-engineer-1
- support-engineer-2
- support-engineer-3

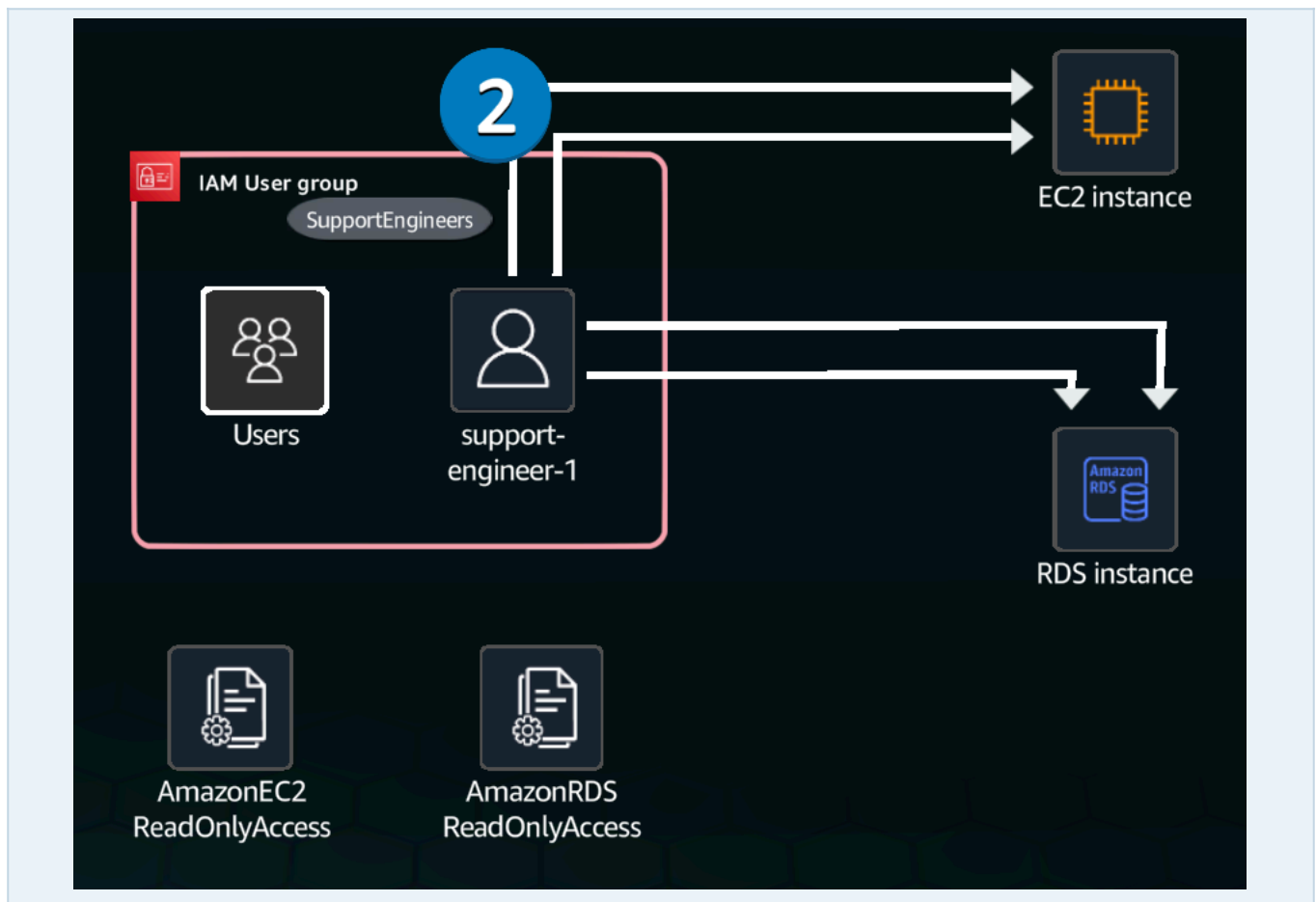
Permissions attached to SupportEngineers:

- AmazonEC2ReadOnlyAccess
- AmazonRDSReadOnlyAccess

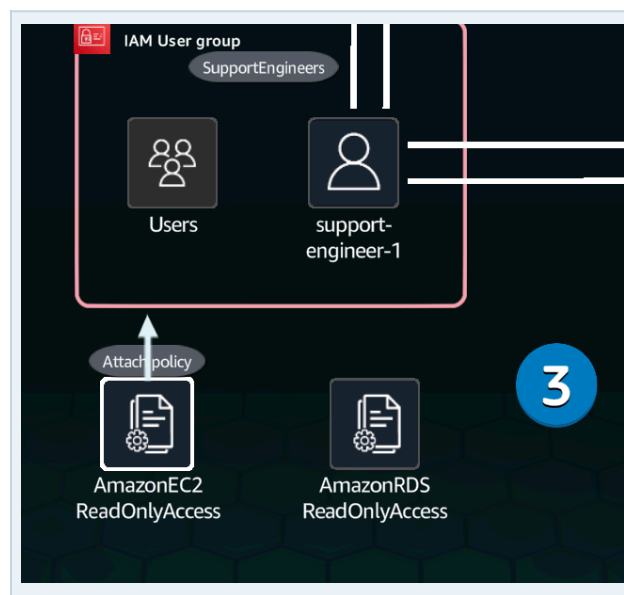
Every user placed in SupportEngineers inherits those permissions.



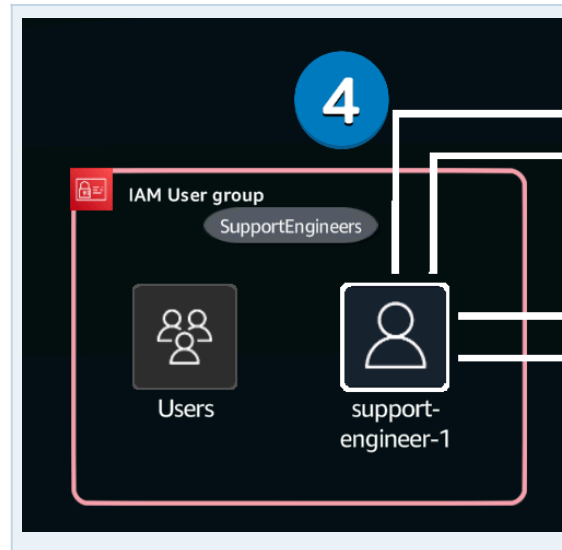
An IAM user group named SupportEngineers acts as a container for IAM users, enabling centralised permissions management through group inheritance.



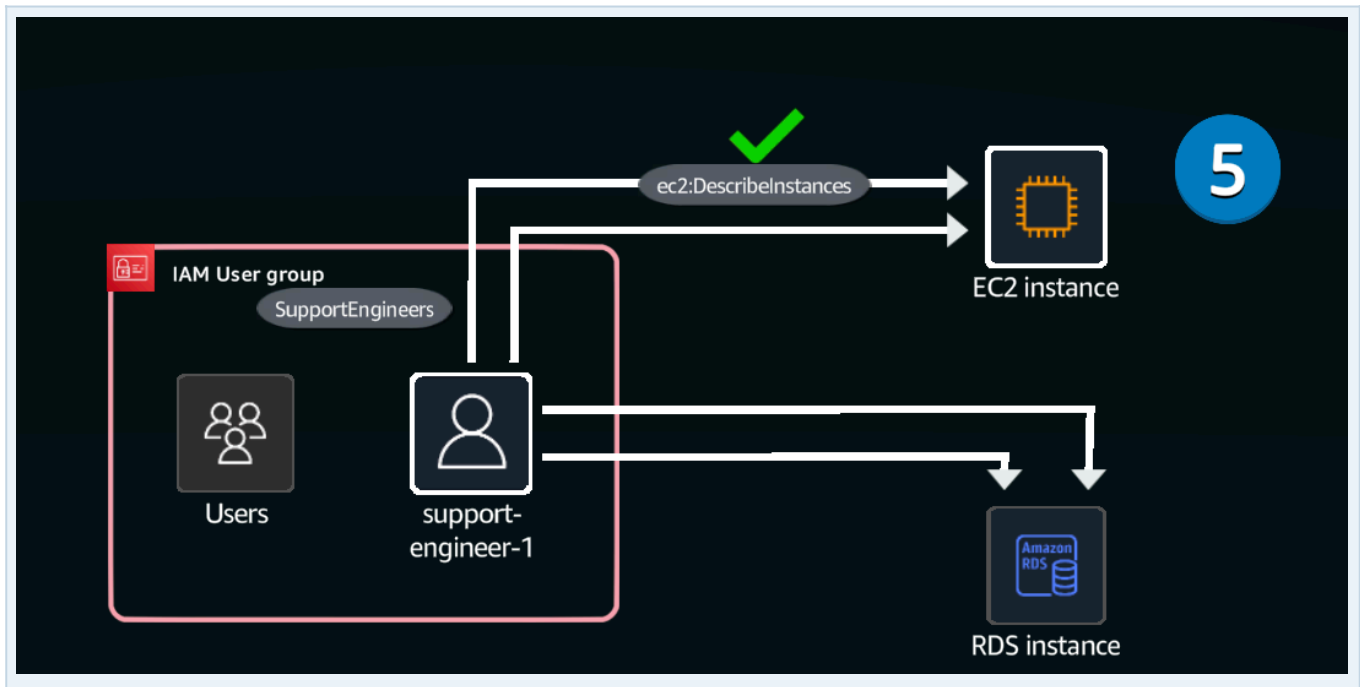
By attaching a read-only policy for Amazon EC2 to the SupportEngineers group, members are limited to read-only operations such as viewing instance information.



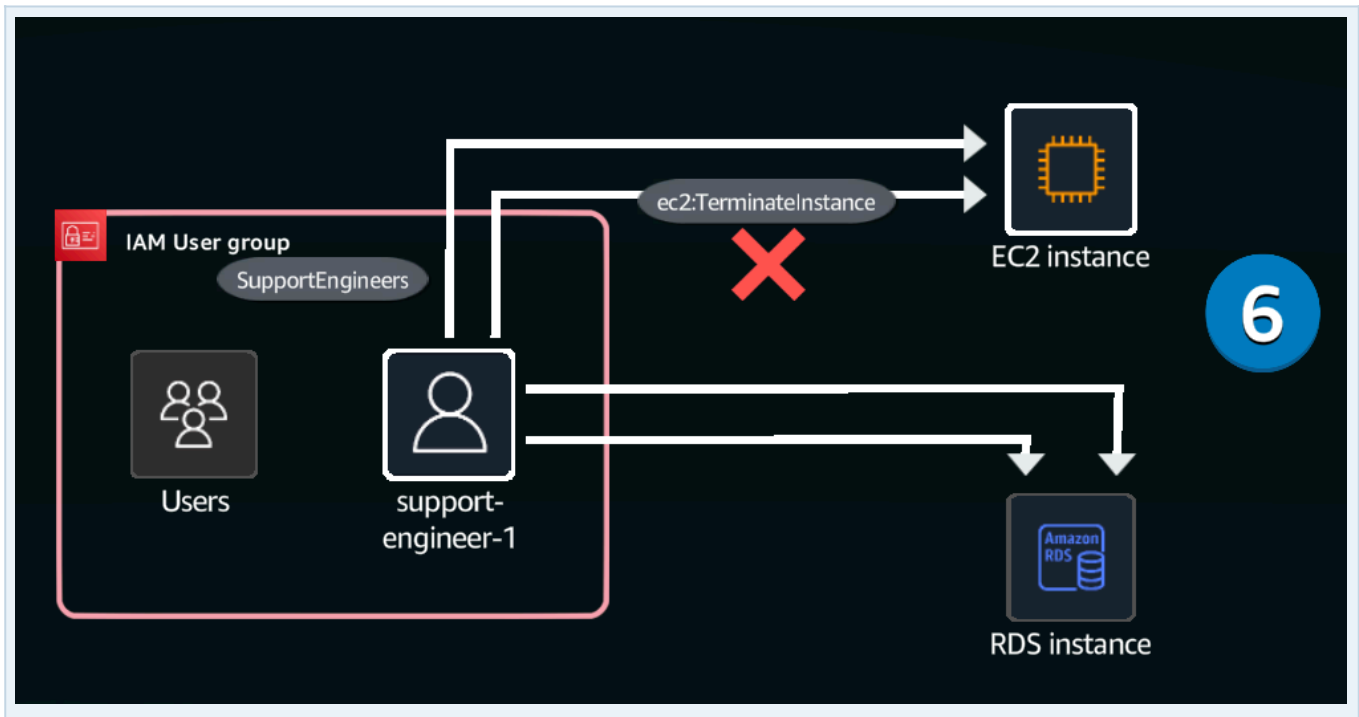
When a new user is added to the group, they inherit the restrictions defined by the policies attached to the group.



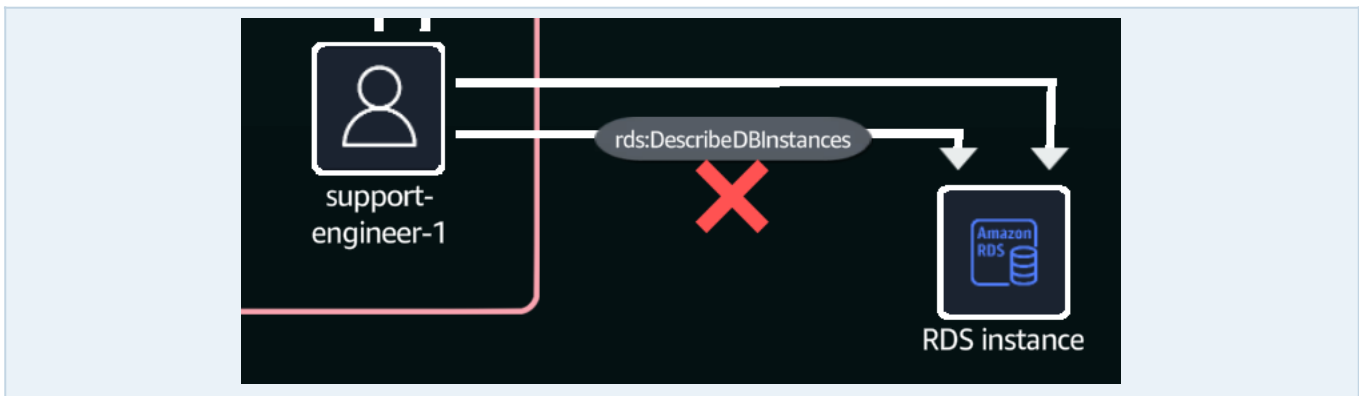
The user successfully retrieves EC2 instance information through read operations.



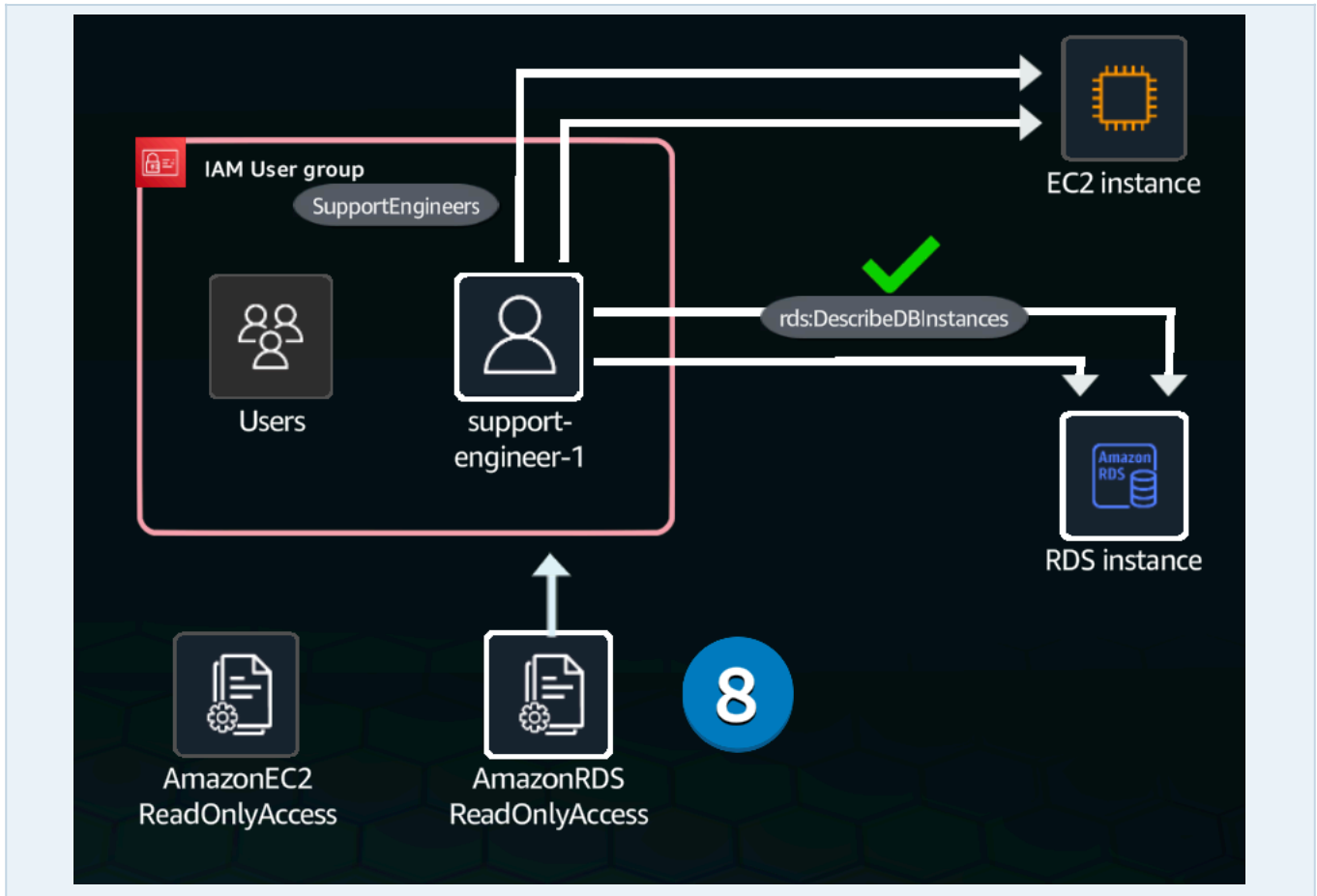
Attempts to terminate instances result in permission errors, preventing changes because the policy restricts the group to read-only actions.



Following AWS's default deny principle, the SupportEngineers group does not have Amazon RDS read access until that permission is explicitly granted.



Adding an RDS read-only policy to the group allows SupportEngineers to view Amazon RDS information.



NOTE: Read means “look at information without changing it.” Support Engineers can see which EC2 instances exist, their status, configuration, instance type, IP address, security groups, VPC/subnet, and similar details.

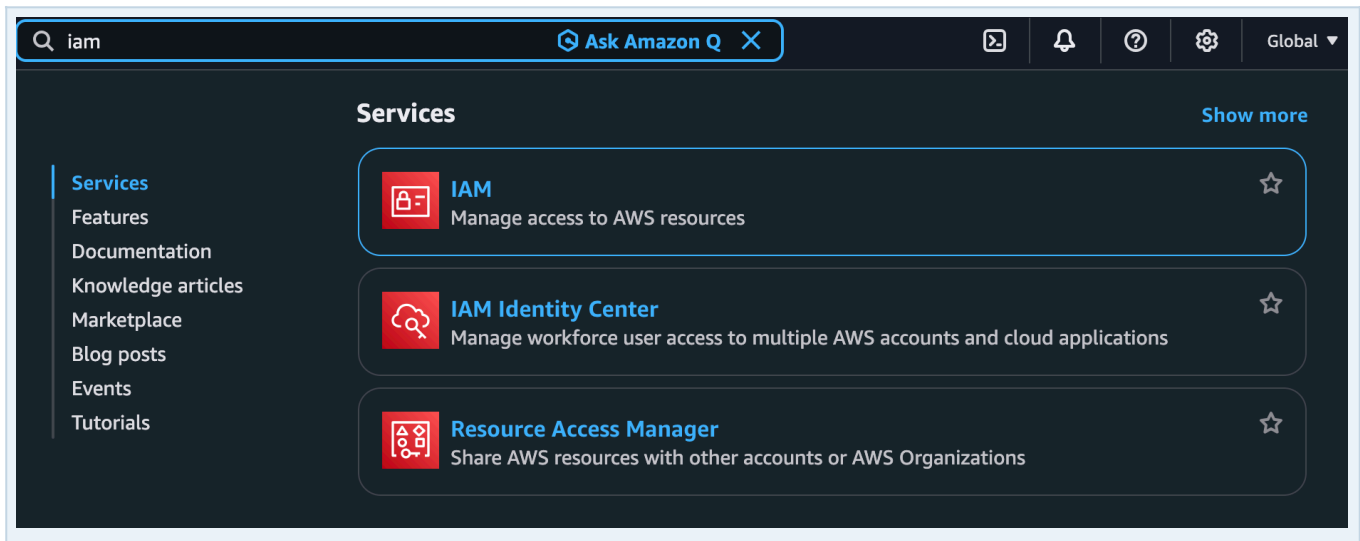
02 Practice Lab

Practice Lab Goals

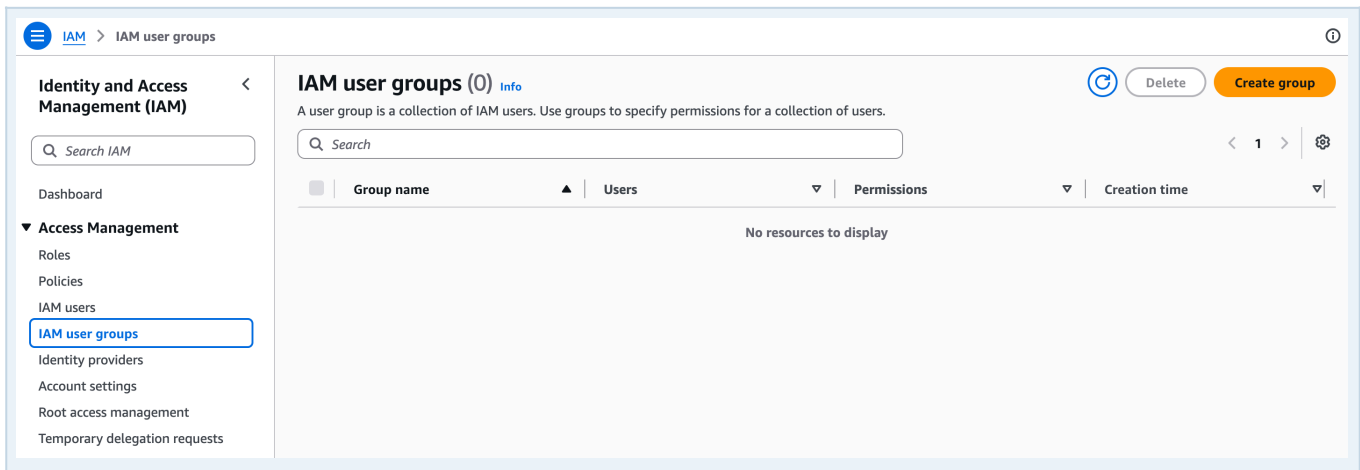
- Create an IAM group and users.
- Attach an AWS managed policy to the group of users.

Create the User Group

Begin by searching for IAM.



Navigate to User Groups → Create Group.



Name the group SupportEngineers.

Under Attach permissions policies, search for AmazonEC2ReadOnlyAccess and select it.

Attach permissions policies - *Optional* (1/1219) [Info](#)

You can attach up to 10 policies to this user group. All the users in this group will have permissions that are defined in the selected policies.

Filter by Type

1 match

☒	Policy name	Type	Used as	Description
☒	AmazonEC2ReadOnlyAccess	AWS managed	None	Provides read only access to Amazon

Cancel
Create user group

Create the First User

After creating the group, navigate to IAM users and create a new user.

Identity and Access Management (IAM)

Dashboard

Access Management

- Roles
- Policies
- IAM users**

SupportEngineers user group created.
View group

IAM users (0) [Info](#)

An IAM user is an identity with long-term credentials that is used to interact with AWS in an account.

1

☐	User name	Path	Group:	Last activity	MFA	Password age	Console last sign-in
No resources to display							

Delete user
Create user

Use the following configuration:

- Username: support-engineer-1
- Provide user access to the AWS Management Console.
- Use a custom password.

User details

User name

The user name can have up to 64 characters. Valid characters: A-Z, a-z, 0-9, and + = , . @ _ - (hyphen)

☒ **Provide user access to the AWS Management Console - *optional***

In addition to console access, users with SignInLocalDevelopmentAccess permissions can use the same console credentials for programmatic access without the need for access keys.

Console password

☐ **Autogenerated password**

You can view the password after you create the user.

☒ **Custom password**

Enter a custom password for the user.

- Must be at least 8 characters long
- Must include at least three of the following mix of character types: uppercase letters (A-Z), lowercase letters (a-z), numbers (0-9), and symbols ! @ # \$ % ^ & * () _ + - (hyphen) = [] { } | ' " , . ; : ' (apostrophe)

☒ **Show password**

☐ **Users must create a new password at next sign-in - Recommended**

Users automatically get the [IAMUserChangePassword](#) policy to allow them to change their own password.

NOTE: This is for lab/debugging purposes. Follow strong password recommendations in real environments.

Add the user to the existing SupportEngineers group so they inherit its permissions.

Permissions options

☒ **Add user to group**
Add user to an existing group, or create a new group. We recommend using groups to manage user permissions by job function.

☐ **Copy permissions**
Copy all group memberships, attached managed policies, and inline policies from an existing user.

☐ **Attach policies directly**
Attach a managed policy directly to a user. As a best practice, we recommend attaching policies to a group instead. Then, add the user to the appropriate group.

User groups (1/1)

☒

Group name [🔗](#)

▲

☐

Users

▼

☐

Attached policies [🔗](#)

▼

☐

Created

▼

☒	SupportEngineers	0	AmazonEC2ReadOnlyAccess	2026-09-10 (2 minutes ago)
-------------------------------------	----------------------------------	---	---	----------------------------

▶ **Set permissions boundary - optional**

Cancel

Previous

Next

Finish by creating a simple tag.

Tags - optional

Tags are key-value pairs you can add to AWS resources to help identify, organize, or search for resources. Choose any tags you want to associate with this user.

Key

×

Value - optional

×

Remove

Add new tag

You can add up to 49 more tags.

Cancel

Previous

Create user

Test the User's Permissions

Once the user is created, copy the console sign-in URL.

Retrieve password

You can view and download the user's password below or email users instructions for signing in to the AWS Management Console. This is the only time you can view and download this password.

Console sign-in details

Email sign-in instructions ↗

Console sign-in URL
https://411181719368.signin.aws.amazon.com/console

User name
support-engineer-1

Console password
***** Show

CancelDownload .csv fileReturn to users list

Navigate back to IAM users.

Identity and Access Management (IAM)

Search IAM

Dashboard

Access Management

Roles

Policies

IAM users

IAM users (1) Info

An IAM user is an identity with long-term

Search

☐

User name

☐

[support-engineer-1](#)

Open the user. If you forget the console sign-in URL, you can find it under Security credentials along with other important details such as MFA.

Permissions
Groups (1)
Tags (1)
Security credentials
Last Accessed

Console sign-in
[Manage console access](#)

Console sign-in link
<https://411181719368.signin.aws.amazon.com/console>

Console password
Updated 2 minutes ago (2026-09-10 13:00 GMT+2)

Last console sign-in
[Never](#)

Multi-factor authentication (MFA) (0)
[Remove](#)
[Resync](#)
[Assign MFA device](#)

Use MFA to increase the security of your AWS environment. Signing in with MFA requires an authentication code from an MFA device. Each user can have a maximum of 8 MFA devices assigned. [Learn more](#)

Type	Identifier	Certifications	Created on
No MFA devices. Assign an MFA device to improve the security of your AWS environment			

[Assign MFA device](#)

Access keys (0)
[Create access key](#)

NOTE: Open an incognito/private browser window and use the console sign-in URL. This lets you stay logged in with the original credentials while testing the new IAM user separately.

Enter the credentials for the first user.

IAM user sign in ⓘ

Account ID or alias ([Don't have?](#))

☐ Remember this account

IAM username

Password

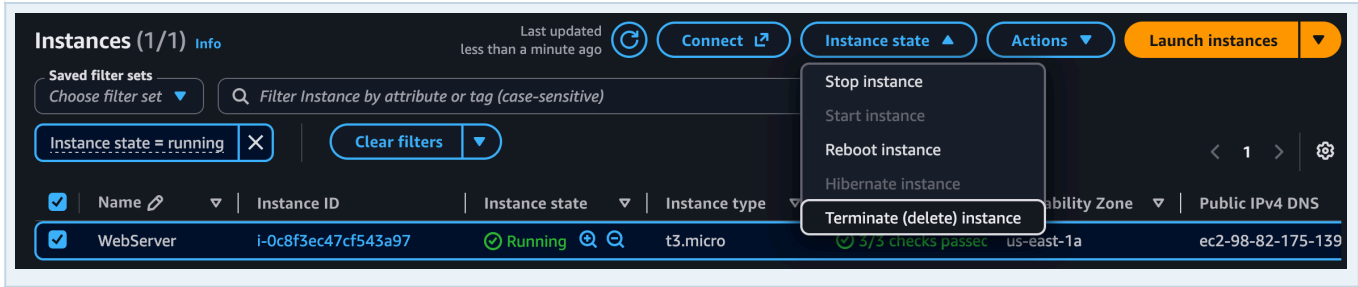
☒ Show Password
[Having trouble?](#)

[Sign in](#)

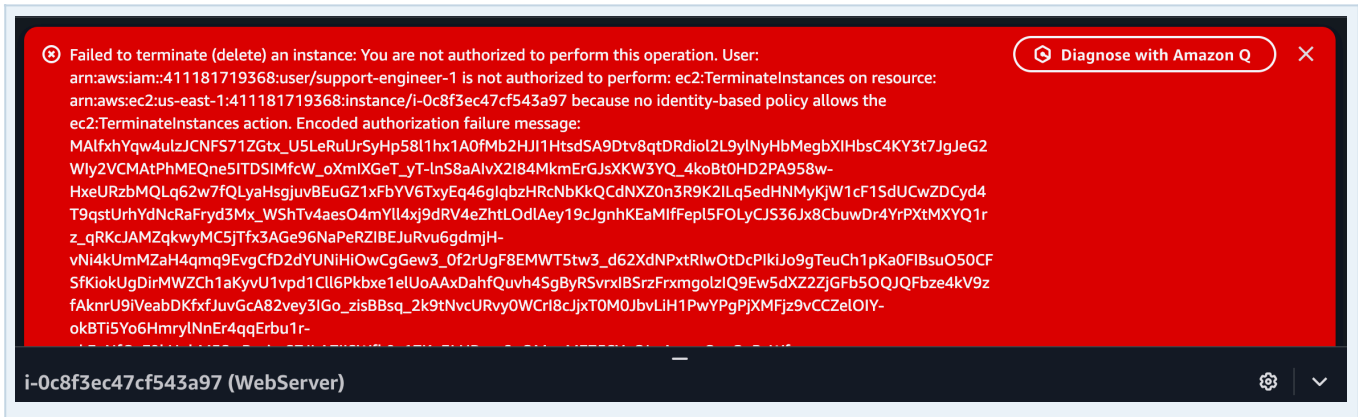
[Sign in using root user email](#)

[Create a new AWS account](#)

After signing in, try to terminate an EC2 instance to verify that the user is denied.

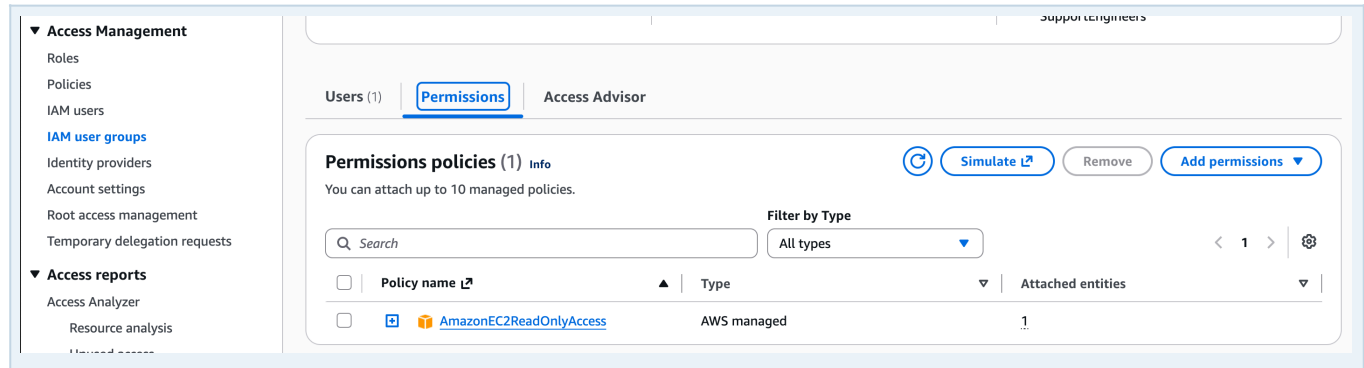


The termination attempt is denied, which is the expected result.

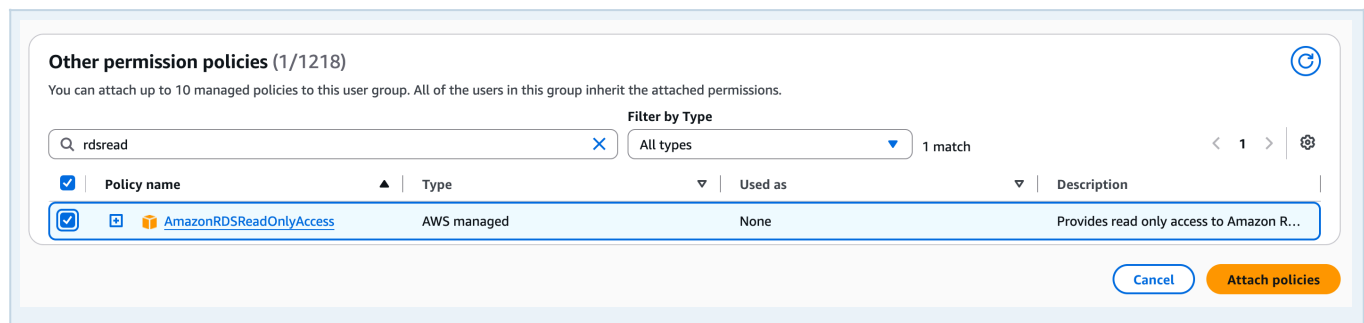


Add RDS Read Access

Additional permissions can be added later by returning to IAM User Groups and choosing Add permissions.



In this case, add read-only access to Amazon RDS for the SupportEngineers group.



Summary

In this lab, we used an IAM group to manage permissions for multiple support engineers from one place. Users added to SupportEngineers inherit the policies attached to the group.

- IAM Group: SupportEngineers.
- Users: Added to the group to inherit its permissions.
- EC2: AmazonEC2ReadOnlyAccess.
- RDS: Read-only access added separately.
- Read-only: Resources can be inspected, but not modified or deleted.
- Default deny: Anything not explicitly allowed remains denied.
- Least privilege: Give users only the permissions required for their job.

NOTE: Managing permissions through groups makes adding new employees easier. Add them to the group, and they automatically inherit the same permissions.